

AN TOÀN THÔNG TIN (INSE330380)

CHƯƠNG IX MÃ HÓA KHÓA BẤT ĐỐI XỨNG (Asymmetric key cipher / public key cipher)

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu bài học
- ☐ Giới thiệu mã hóa khóa bất đối xứng (hoặc mã hóa khóa công khai)
- ☐ Toán học liên quan đến mã hóa
- ☐ Thuật toán RSA
- ☐ Thuật toán trao đổi khóa Diffie and Hellman
- ☐ Giao thức quản lý Key
- ☐ Tóm tắt

❑ Mã hóa (khóa) bất đối xứng là một dạng hệ thống mật mã trong đó việc mã hóa và giải mã được thực hiện bằng các khóa khác nhau, còn được gọi là mã hóa khóa công khai

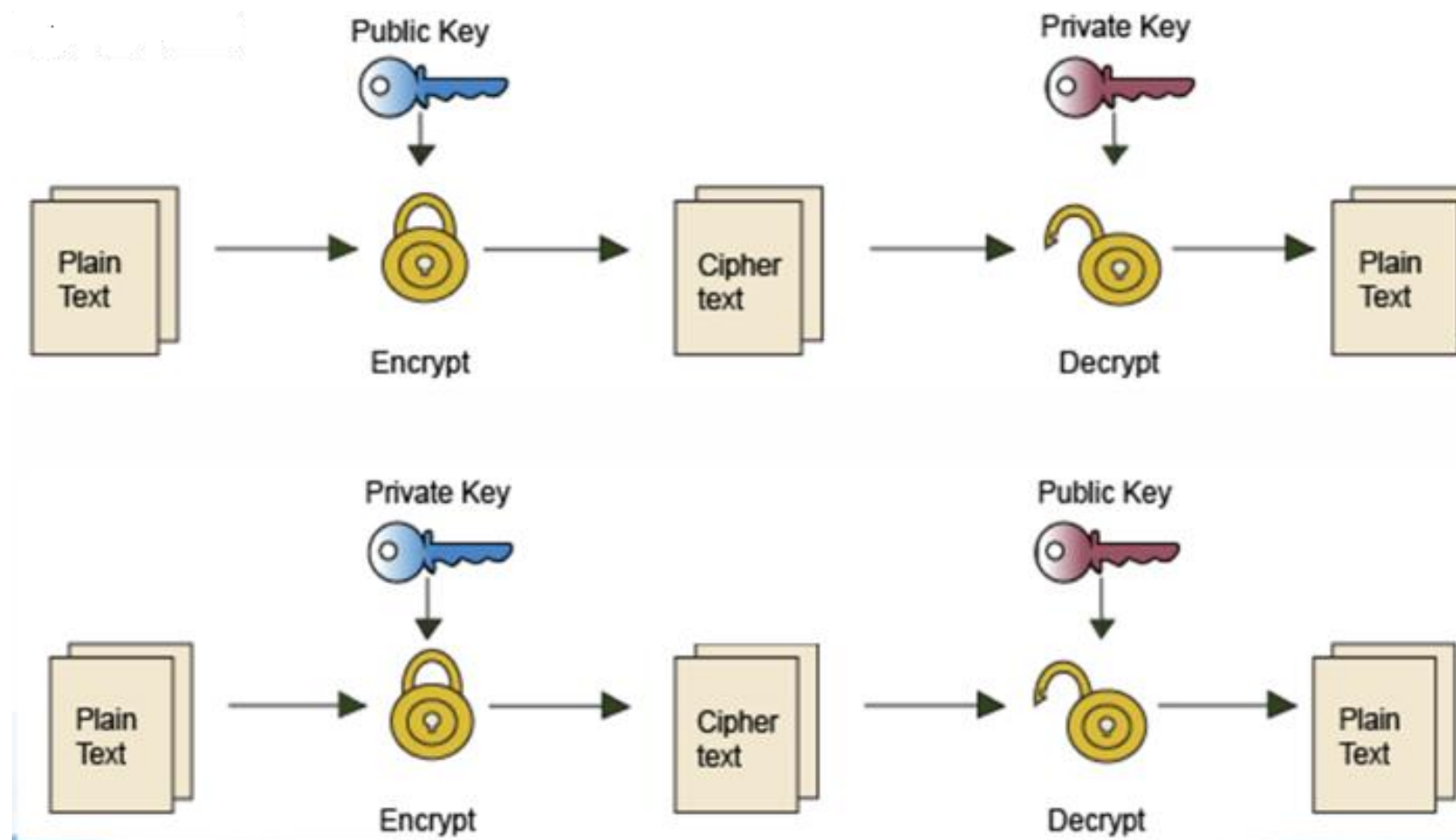
❑ a public key

- Sử dụng để mã hóa tin nhắn hoặc
- Để kiểm tra chữ ký của người sở hữu chìa khóa.

❑ a private key.

- Sử dụng để giải mã tin nhắn hoặc
- Để tạo chữ ký

❑ Ví dụ mô hình



- ❑ Số nguyên tố
- ❑ Hàm Euler's Phi
- ❑ Thuật toán Euclid GCD – tìm ước chung lớn nhất
- ❑ Phép đồng dư - modulo
 - Định lý Fermat Little
 - Định lý Euler
 - Nghịch đảo modulo
- ❑ Thuật toán Euclid mở rộng (Extend-Euclid)

- ❑ Mật mã khóa bất đối xứng sử dụng các số nguyên tố rất nhiều
- ❑ Một số nguyên dương là số nguyên tố khi và chỉ khi nó chia hết cho hai số nguyên 1 và chính nó.
- ❑ Ví dụ: Liệt kê các số nguyên tố nhỏ hơn 10.

❑ Thuật toán:

```
Prime_Test(n)
{
   $r \leftarrow 2$ 
  while ( $r < \sqrt{n}$ )
  {
    if ( $r \mid n$ ) return "a composite"
     $r \leftarrow r + 1$ 
  }
  return "a prime"
}
```

- ❑ Euler's Phi đóng vai trò rất quan trọng trong mật mã $f(n)$
- ❑ Hàm tìm số nguyên vừa nhỏ hơn n vừa nguyên tố cùng nhau với n .
- ❑ Để tìm giá trị của $f(n)$, có 4 luật sau:

$$\phi(1) = 0.$$

$$\phi(p) = p - 1, \text{ nếu } p \text{ là số nguyên tố}$$

$$\phi(m \times n) = \phi(m) \times \phi(n) \text{ nếu } m \text{ và } n \text{ là nguyên tố tương đối nhau}$$

$$\phi(p^e) = p^e - p^{e-1} \text{ nếu } p \text{ là số nguyên tố}$$

- ❑ Ví dụ:

$$\phi(13) = (13 - 1) = 12. \quad \phi(10) = \phi(2) \times \phi(5) = 1 \times 4 = 4$$

□ Ước chung lớn nhất $\text{GCD}(a,b)$ của a và b là số lớn nhất chia hết cho cả a và b

■ $\text{GCD}(a,b)$: $\text{GCD}(a,b) = \text{GCD}(b, a \bmod b)$

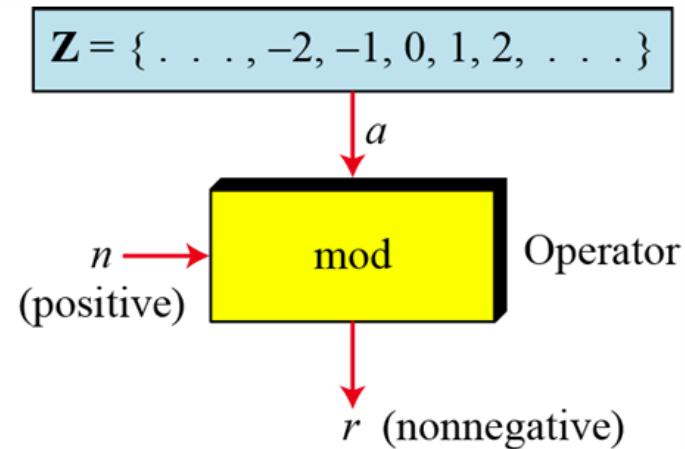
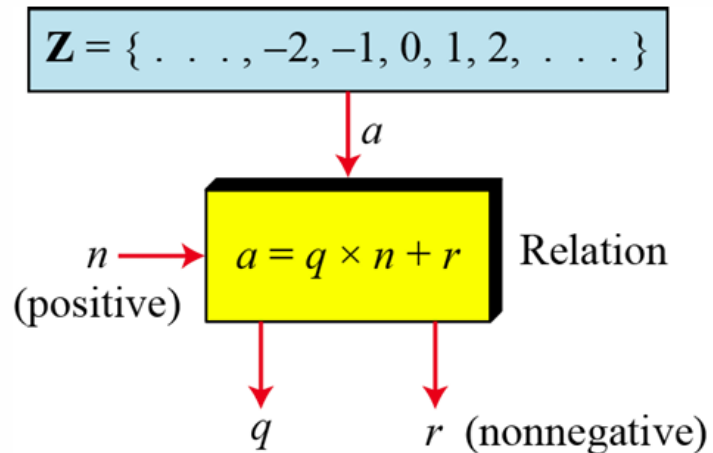
```

EUCLID(a,b)
1. A = a; B = b
2. if B = 0 return A=gcd(a,b)
3. R = A mod B
4. A = B
5. B = R
6. goto 2
  
```

a	b	r
24	63	24
63	24	15
24	15	9
15	9	6
9	6	3
6	3	0

□ Ví dụ: $\text{GCD}(24,63)$

□ Chia dư



□ Ví dụ:

- a. $27 \bmod 5$
- c. $-18 \bmod 14$

- b. $36 \bmod 12$
- d. $-7 \bmod 10$

□ $a = q \times n + r$

□ Trong đó:

□ $a \rightarrow$ số bị chia (số nguyên bất kỳ)

□ $n \rightarrow$ số chia (số nguyên dương)

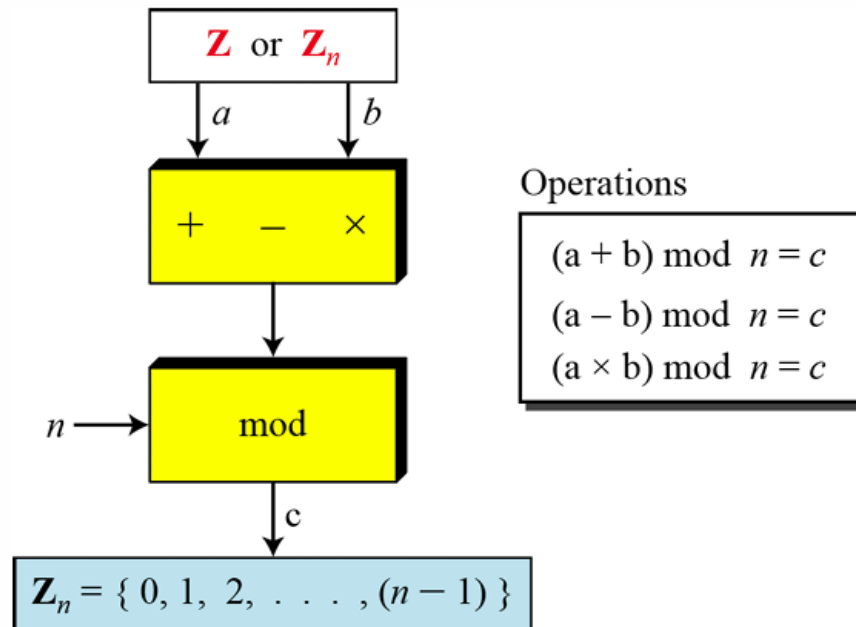
□ $q \rightarrow$ thương (quotient)

□ $r \rightarrow$ phần dư (remainder), luôn thỏa mãn $0 \leq r < n$

□ Khi a là số âm, nhiều người hay nhầm lấy phần dư âm. Quy tắc đúng là:

□ Phải chọn q sao cho $r \geq 0$, tức là làm tròn q xuống (về phía âm vô cực)

□ Tính chất



□ Ví dụ:

$$\begin{aligned} (14 + 7) \bmod 15 &\rightarrow (21) \bmod 15 = 6 \\ (7 - 11) \bmod 13 &\rightarrow (-4) \bmod 13 = 9 \\ (7 \times 11) \bmod 20 &\rightarrow (77) \bmod 20 = 17 \end{aligned}$$

□ Với một số nguyên $n > 1$, gọi là mô đun, hai số nguyên a và b được gọi là đồng dư modulo n , nếu hiệu của chúng chia hết cho n

- Nếu tồn tại số nguyên k sao cho $a - b = kn$
- Hay $a \equiv b \pmod{n}$ nếu a và b có cùng số dư khi chia cho n (số dư modulo n)

□ Tính chất:

$$\begin{array}{l} \text{If } a \equiv b \pmod{m} \text{ and} \\ c \equiv d \pmod{m}, \text{ then} \\ a + c \equiv b + d \pmod{m}. \end{array}$$

$$\begin{array}{l} \text{If } a \equiv b \pmod{m} \text{ and} \\ c \equiv d \pmod{m}, \text{ then} \\ a \times c \equiv b \times d \pmod{m}. \end{array}$$

□ Ví dụ: $9+18 \pmod{4} \equiv ? \pmod{4}$.

$$1 \equiv 9 \pmod{4}, 2 \equiv 18 \pmod{4} \Rightarrow 9+18 \pmod{4} \equiv 1+2 \pmod{4}.$$

- ❑ Trong mật mã, một phép toán mô-đun phổ biến là phép tính lũy thừa:
- ❑ Exponentiation: $y = a^x \rightarrow \text{Logarithm: } x = \log_a y$
- ❑ RSA sử dụng cho cả mã hóa và giải mã với số mũ rất lớn. Tìm đồng dư: $y \equiv a^x \pmod n$
- ❑ Có thể tính lũy thừa nhanh bằng cách sử dụng phương pháp bình phương và nhân

$$y = a^{x_{n_b-1} \times 2^{n_b-1} + x_{n_b-2} \times 2^{n_b-2} + \dots + x_1 \times 2^1 + x_0 \times 2^0}$$

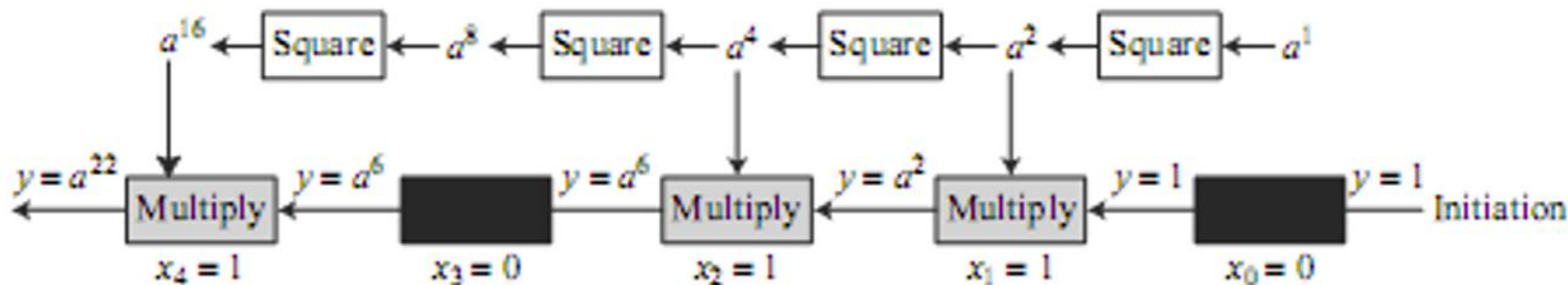
in which x_i is 0 or 1

$$y = a^{2^{n_b-1} \text{ or } 1} \times a^{2^{n_b-2} \text{ or } 1} \times \dots \times a^{2^1 \text{ or } 1} \times a^{2^0 \text{ or } 1}$$

❑ Ví dụ: $y = a^9 = a^{1001_2} = a^8 \times 1 \times 1 \times a$

❑ Ví dụ tính đồng dư: $17^{(22)} \bmod 21$. Sử dụng phương pháp bình phương và nhân

❑ $x = 22 = (10110)_2 \Rightarrow y = a^{16} \cdot a^4 \cdot a^2$



$$17^2 \bmod 21 = 16 ; 17^4 \bmod 21 = 16^2 \bmod 21 = 4 ; 17^8 \bmod 21 = 4^2 \bmod 21 = 16$$

$$17^{16} \bmod 21 = 16^2 \bmod 21 = 4$$

$$\Rightarrow y = 4 \cdot 4 \cdot 16 = 16^2 \bmod 21 = 4$$

❑ Định lý nhỏ Fermat đóng vai trò rất quan trọng trong lý thuyết số và mật mã học.

❑ Có 2 phiên bản

Nếu p là số nguyên tố và a là số nguyên sao cho $\gcd(a, p) = 1$ thì

$$a^{p-1} \equiv 1 \pmod{p}$$

Nếu p là số nguyên tố và a là số nguyên thì

$$a^p \equiv a \pmod{p}$$

❑ Nghịch đảo modulo: Nếu p là số nguyên tố và a là số nguyên sao cho p không chia hết a , ($\gcd(a, p) = 1$) thì:

$$a^{-1} \pmod{p} = a^{p-2} \pmod{p}$$

- ❑ Định lý Euler là sự khái quát hóa của định lý Fermat.
 - Modulus trong Fermat là số nguyên tố, còn trong Euler là một số nguyên
- ❑ Có 2 phiên bản: được dùng trong mã hóa RSA

Nếu a và n là 2 số nguyên tố cùng nhau, tức $\gcd(a, n) = 1$ thì

$$a^{\phi(n)} \equiv 1 \pmod{n}$$

Nếu $n = p \times q$, $a < n$ và k là số nguyên thì

$$a^{k \times \phi(n) + 1} \equiv a \pmod{n}$$

- ❑ Nghịch đảo modulo: a và n là số nguyên tố cùng nhau thì: $a^{-1} \pmod{n} = a^{\phi(n)-1} \pmod{n}$

- ❑ Nghịch đảo cộng phép modulo: $a + b \equiv 0 \pmod{n}$
- ❑ Nghịch đảo nhân phép modulo: $a * b \equiv 1 \pmod{n}$
- ❑ Khi đó: b là nghịch đảo cộng/nhân của phép modulo $a \bmod n$
- ❑ Ví dụ:
 - Add: (mod 10): (0, 0), (1, 9), (2, 8), (3, 7), (4, 6), and (5, 5).
 - Mul: (mod 10): (1, 1), (3, 7) and (9, 9).

- ❑ RSA là một loại mật mã khóa công khai nổi tiếng và phổ biến rộng rãi.
- ❑ Được được phát triển bởi Ron Rivest, Adi Shamir và Leonard Adleman (RSA là viết tắt của 3 tác giả) lần đầu vào năm 1977 (MIT)
- ❑ Nó dựa trên phép lũy thừa trên Trường Galois của các số nguyên của số nguyên tố modulo
- ❑ Bảo mật RSA dựa trên độ mạnh của phân tích nhân tử và bài toán logarit rời rạc
- ❑ RSA đã được đăng ký bản quyền ở Bắc Mỹ và một số nước khác.

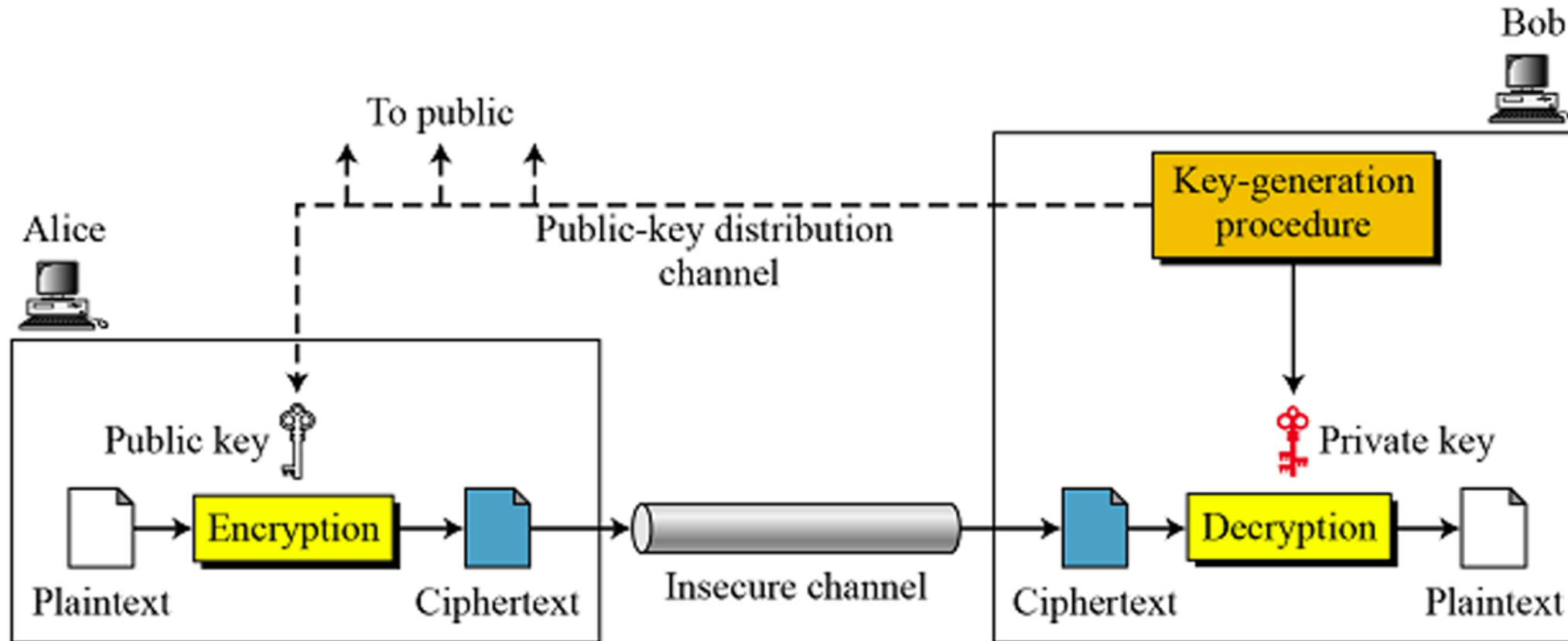
RSA hoạt động như thế nào

RSA dựa trên 2 phép lũy thừa đồng dư:

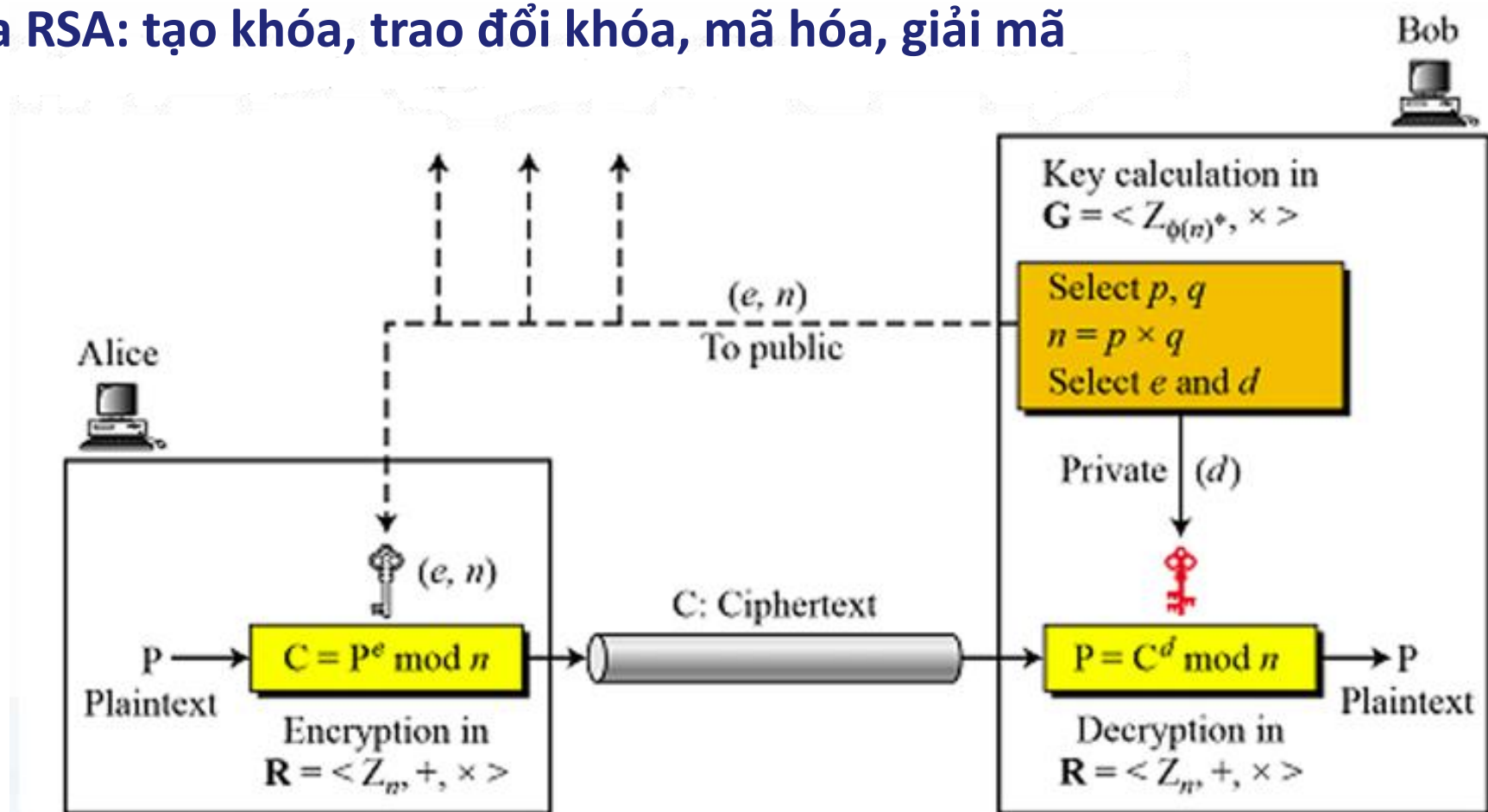
$$\text{Mã hóa: } C = M^e \bmod n$$

$$\text{Giải mã: } M = C^d \bmod n$$

❑ Hệ thống tổng quan của mật mã khóa bất đối xứng.

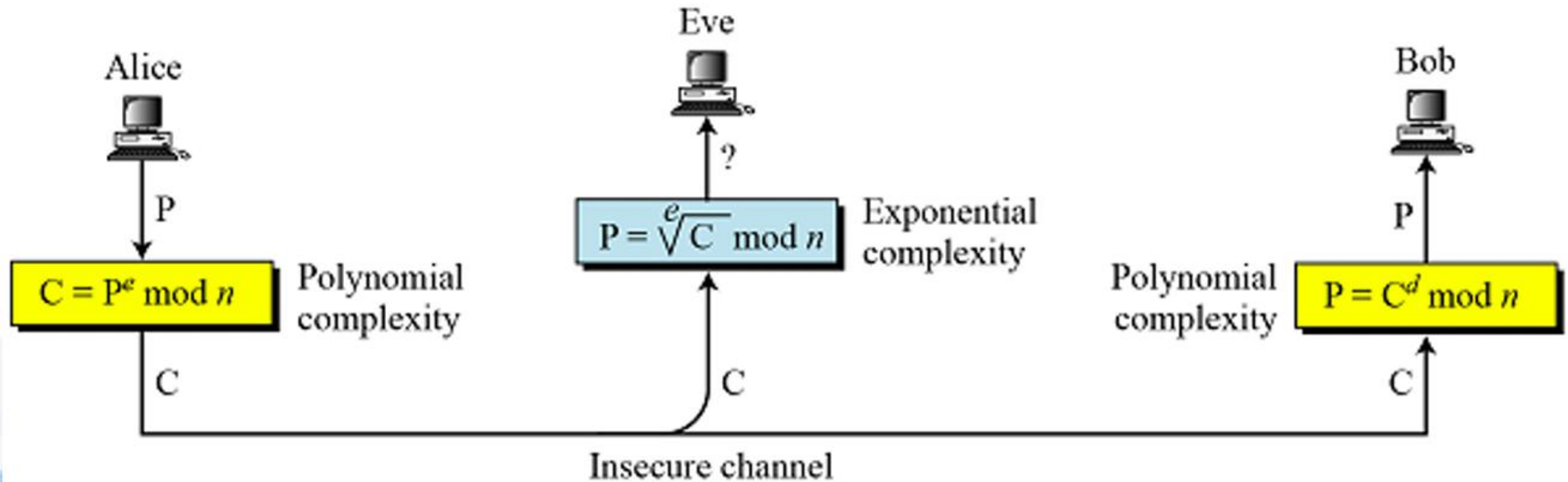


❑ Các thủ tục của RSA: tạo khóa, trao đổi khóa, mã hóa, giải mã



❑ Sự phức tạp của các hoạt động trong RSA

- Eve chỉ biết C , ko thể giải mã thông điệp.
- Để tấn công, Eve cần tính đa thức modulo căn bậc e của C



❑ Sử dụng cặp khóa

Encryption $C = M^e \bmod n$, $M < n$ using public key

Decryption: $M = C^d \bmod n$ using private key

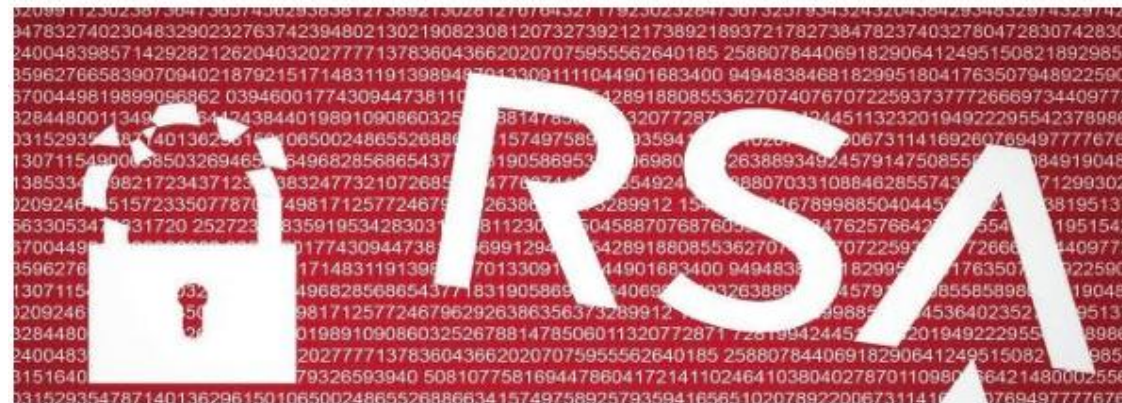
Signature: $S = M^d \bmod n$, $M < n$ using private key

Verification: $M = S^e \bmod n$ using public key

- ❑ Độ dài khóa thay đổi
- ❑ Kích thước khối văn bản gốc thay đổi
 - Bản rõ được coi là số nguyên và phải “nhỏ hơn” khóa
 - Kích thước khối văn bản mã hóa bằng độ dài khóa
- ❑ Tính bảo mật của RSA phụ thuộc vào độ khó của việc tính toán các số nguyên lớn.
 - Những số nguyên càng lớn, càng phức tạp thì bảo mật RSA lại càng cao.
 - Kích thước key sẽ quyết định tới độ mạnh mã hóa.
 - Tăng gấp đôi độ dài của các key thì sức mạnh mã hóa tăng cũng tăng theo tuy nhiên điều này lại khiến hiệu suất hoạt động giảm.



- ❑ Tấn công Brute force: Điều này liên quan đến việc thử tất cả các khóa riêng có thể.
- ❑ Tấn công toán học: Có một số cách tiếp cận, tất cả đều tương đương với nỗ lực phân tích tích của hai số nguyên tố.
- ❑ Tấn công định thời: Điều này phụ thuộc vào thời gian chạy của thuật toán giải mã.
- ❑ Tấn công bằng bản mã được chọn (Chosen ciphertext) : Kiểu tấn công này khai thác các thuộc tính của thuật toán RSA.



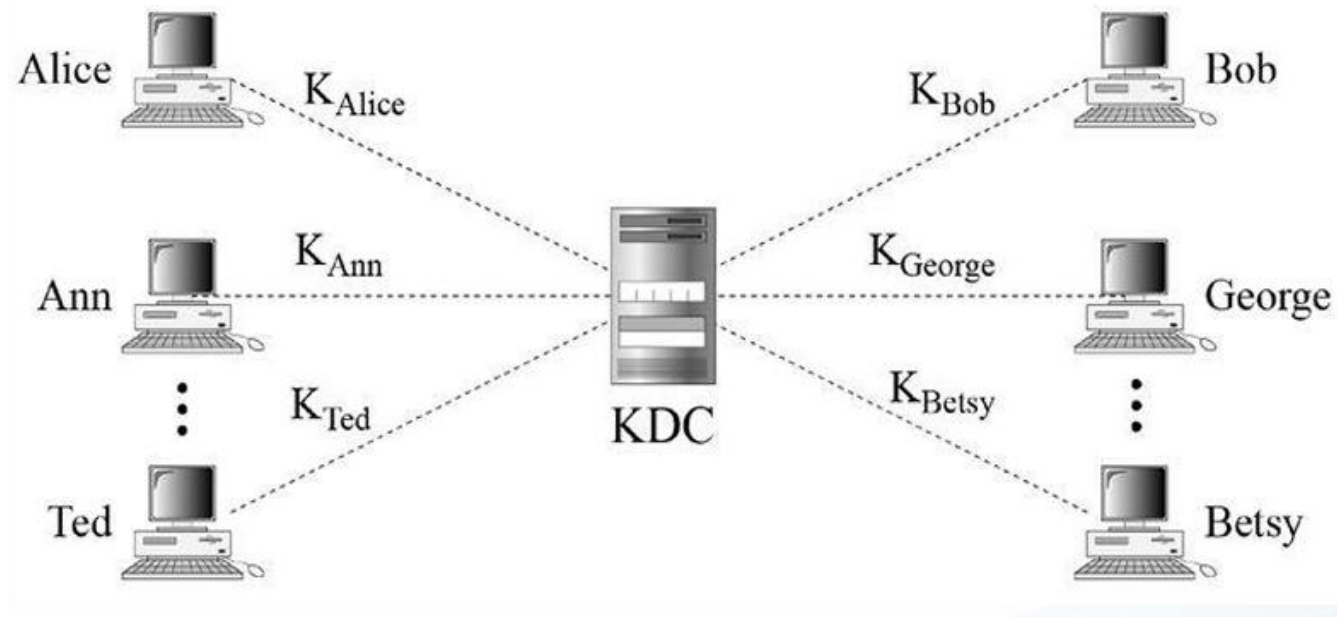
- ❑ Trong mật mã, việc phân phối khóa Public và khóa Private giữa người gửi và người nhận là một công việc quan trọng.
 - Nếu bên thứ ba biết khóa (kẻ giả mạo/kẻ nghe trộm) thì toàn bộ cơ chế bảo mật sẽ trở nên vô giá trị. Vì vậy, xuất hiện nhu cầu đảm bảo việc trao đổi khóa an toàn.
- ❑ Quản lý khóa đề cập đến việc quản lý các khóa mật mã trong hệ thống mật mã, gồm:
 - Xử lý việc tạo, trao đổi, lưu trữ, sử dụng, chia nhỏ (hủy) mật mã và thay thế khóa.
 - Liên quan đến khóa ở cấp độ người dùng, giữa người dùng hoặc hệ thống.

❑ KDC (Key-Distribution Center) là một hệ thống chịu trách nhiệm cung cấp khóa cho người dùng trong mạng chia sẻ dữ liệu quan trọng hoặc riêng tư

- Sử dụng bên thứ ba đáng tin cậy
- Giảm số lượng key
- Ngăn MITM mạo danh một trong hai

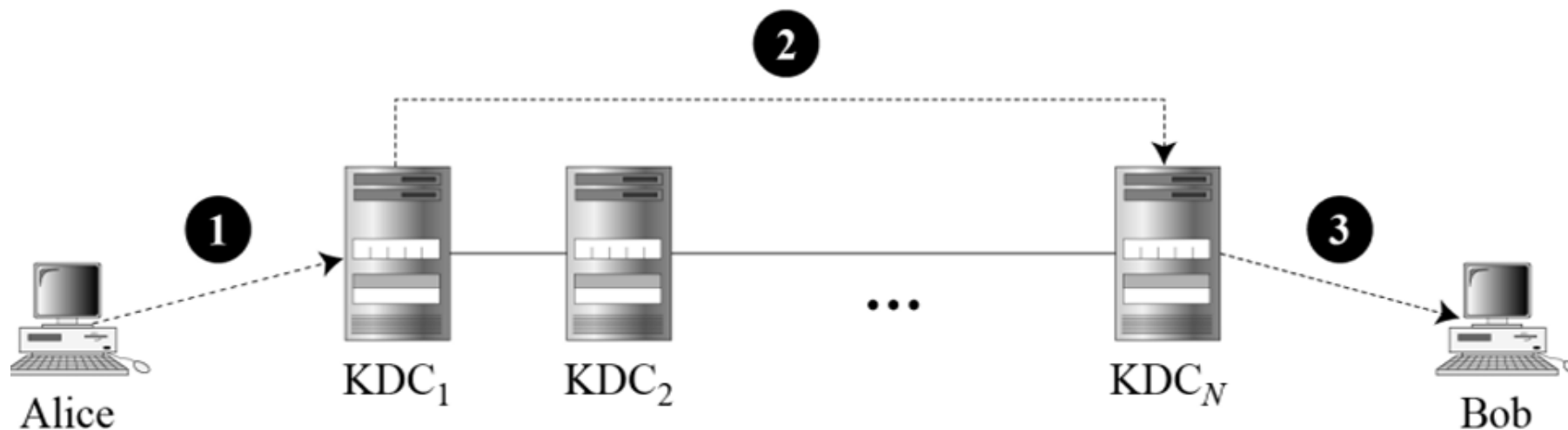
❑ Hoạt động:

- Mỗi người thiết lập khóa bí mật chung với KDC
- Một khóa bí mật được thiết lập giữa KDC và mỗi thành viên bảo mật.

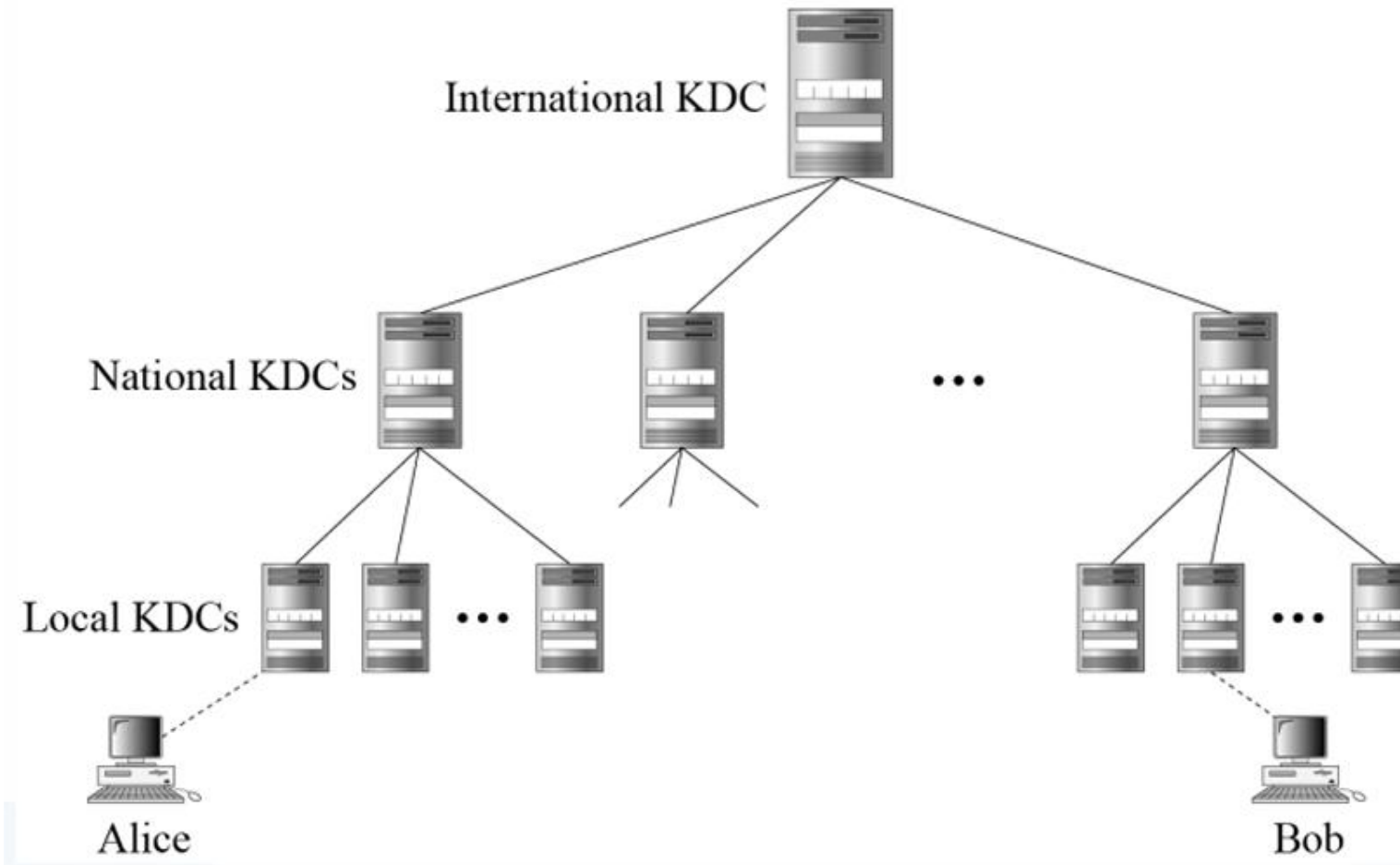


❑ Flat Multiple KDC

- Tránh tình trạng hệ thống không thể quản lý và bị nghẽn cổ chai khi số lượng người sử dụng KDC tăng lên
- Chia toàn hệ thống thành các miền.
- Mỗi miền có thể có một hoặc nhiều KDC (để dự phòng trong trường hợp bị lỗi).



- ❑ Hierarchical Multiple KDCs: là mở rộng của at multiple KDCs



❑ Khóa phiên (Session key):

- KDC tạo khóa bí mật cho mỗi thành viên, khóa này chỉ có thể được sử dụng giữa thành viên và KDC, không được sử dụng giữa 2 thành viên.
- Sau khi KDC xác minh danh tính máy khách và máy chủ là hợp lệ, KDC sẽ tạo khóa phiên (session key), đây là khóa đối xứng sẽ được sử dụng riêng cho phiên hiện tại
- Khóa phiên chỉ được sử dụng một lần, sau giao tiếp kết thúc thì khóa phiên không còn tác dụng

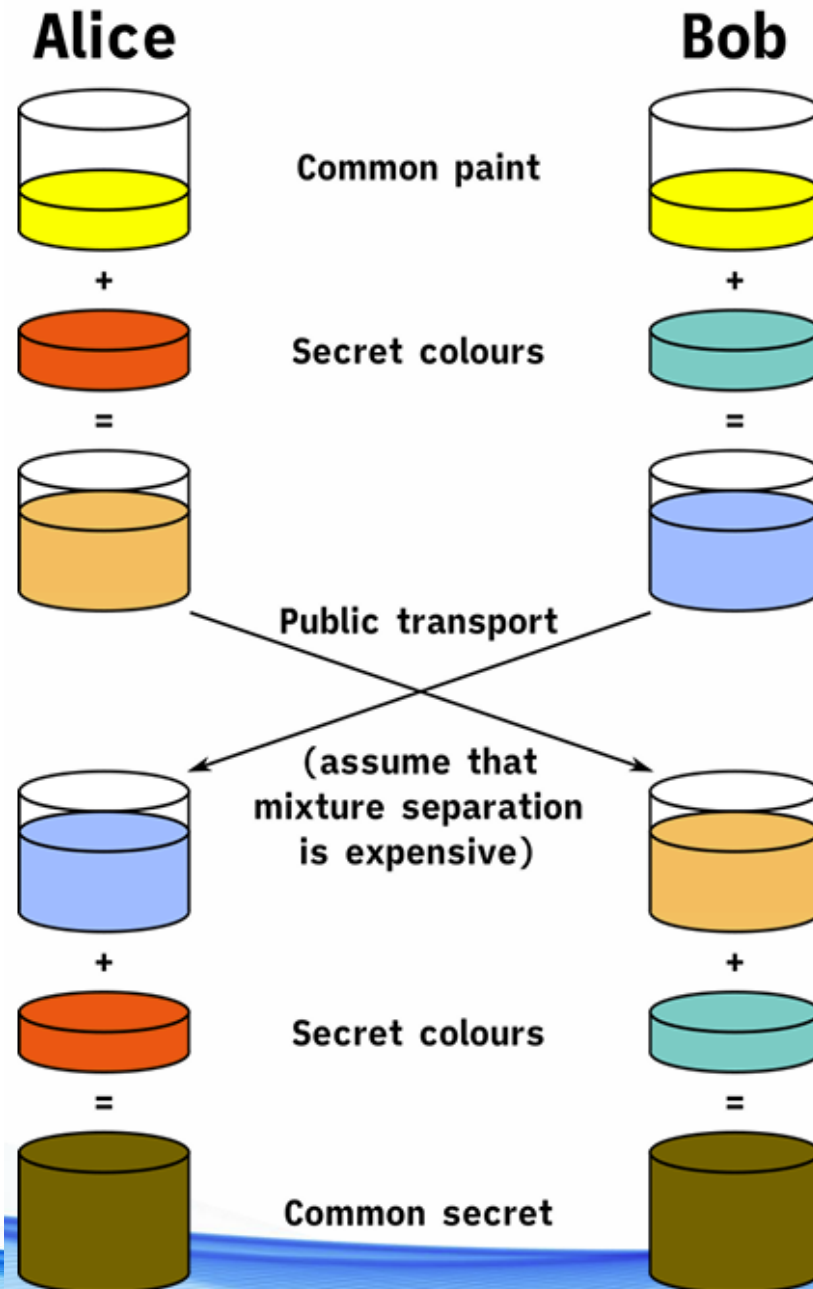
❑ Kerberos

- Là một giao thức xác thực, đồng thời là một KDC, đã trở nên rất phổ biến.
- Ở Windows 2000, sử dụng Kerberos để chứng thực
- Thiết kế đầu tiên được thực hiện tại MIT, nó có nhiều phiên bản khác nhau

❑ Thành phần của Kerberos: Ba máy chủ có liên quan đến giao thức Kerberos:

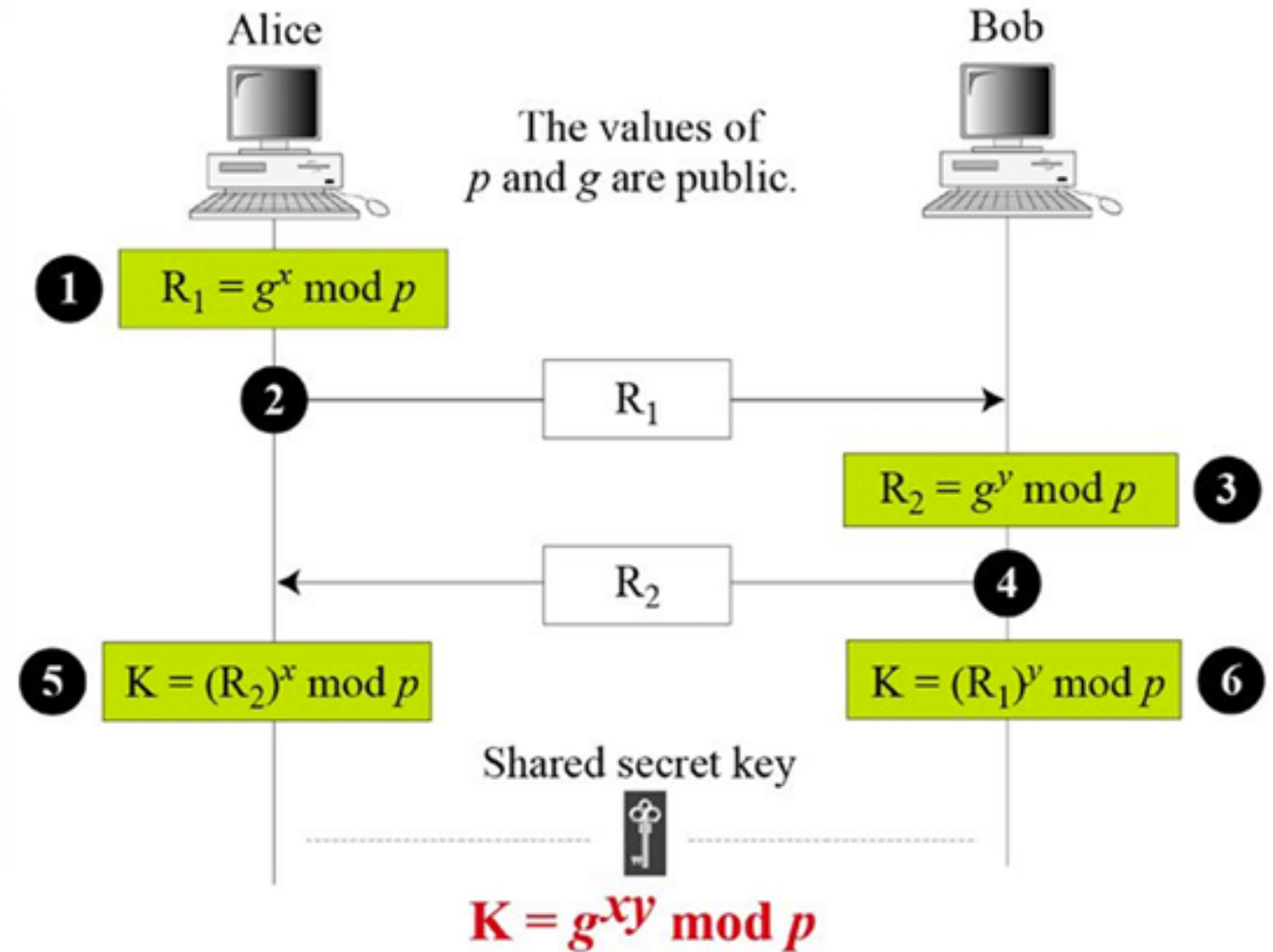
- Máy chủ xác thực (AS-authentication server): là KDC trong Kerberos
- Máy chủ cấp vé (TGS-ticket-granting server): cấp phát thẻ cho Server dữ liệu
- Máy chủ (dữ liệu) thực: cung cấp dịch vụ cho người dùng

- ❑ Thuật toán trao đổi khóa công khai được phát triển lần đầu tiên bởi Diffie Hellman vào năm 1976 cùng với việc trình bày các khái niệm khóa công khai
- ❑ Được sử dụng trong một số sản phẩm thương mại
- ❑ Phương pháp thực tế để trao đổi khóa bí mật một cách an toàn, sau đó có thể được sử dụng để mã hóa tin nhắn
- ❑ Bảo mật phụ thuộc vào độ khó của việc tính toán logarit rời rạc



❑ Quá trình thực hiện

❑ $(R_2)^x = (gy)^x = gxy = (gx)y = (R_1)y$



□ Diffie-Hellman hiện được sử dụng trong nhiều giao thức, cụ thể là:

- Secure Sockets Layer (SSL)/Transport Layer Security (TLS)
- Secure Shell (SSH)
- Internet Protocol Security (IPSec)
- Public Key Infrastructure (PKI)

- ❑ Diffie-Hellman hoạt động theo cấp số nhân
 - Nó đòi hỏi nhiều về mặt tính toán, do đó, nó dễ bị tấn công Dos – làm tắc nghẽn trong đó đối thủ yêu cầu một số lượng khóa cao
- ❑ Bản thân sơ đồ này không thể được sử dụng để mã hóa bất cứ thứ gì - nó dùng để thiết lập khóa bí mật
 - Không có xác thực, vì vậy không thể ký bất cứ điều gì

❑ Tấn công logarit rời rạc

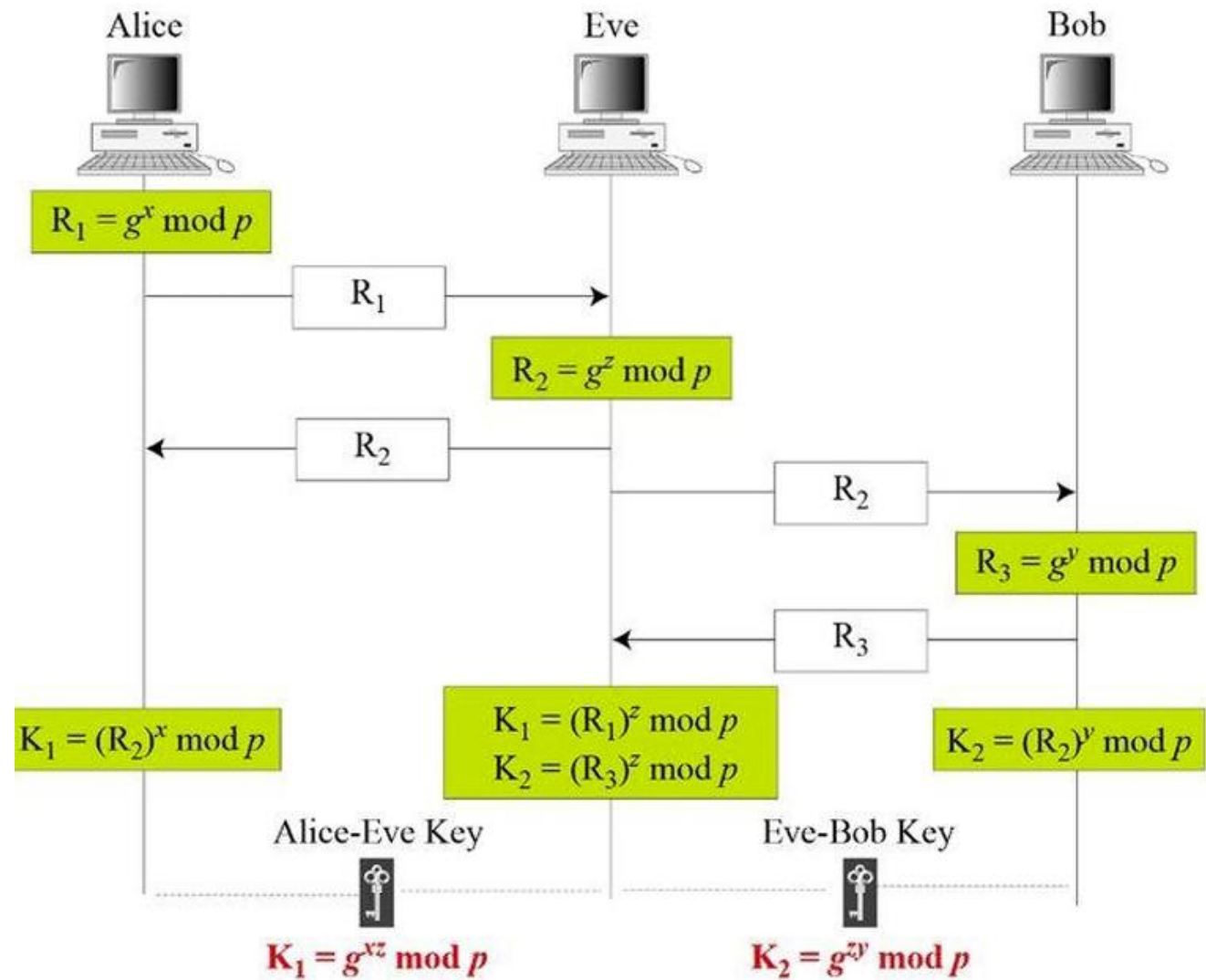
- Eve có thể bắt chặn R1 và R2.
- Nếu có thể tìm được x từ $R1 = g^x \bmod p$ và y từ $R2 = g^y \bmod p$, thì có thể tính khóa đối xứng $K = g^{xy} \bmod p$.
- Khóa bí mật không còn là bí mật nữa.

❑ Để an toàn, ta nên chọn

- Số nguyên tố p phải rất lớn (hơn 300 chữ số), và được chọn sao cho p-1 có ít nhất một thừa số nguyên tố lớn (hơn 60 chữ số).
- 2 bên phải hủy x và y sau khi tính K (x,y chỉ được dùng 1 lần)

❑ Tấn công MITM:

- Attack không cần phải tìm giá trị của x và y
- Đánh lừa Alice và Bob bằng cách tạo ra hai khóa:
 - ✓ Một chiếc giữa mình và Alice,
 - ✓ Và chiếc khác giữa mình và Bob

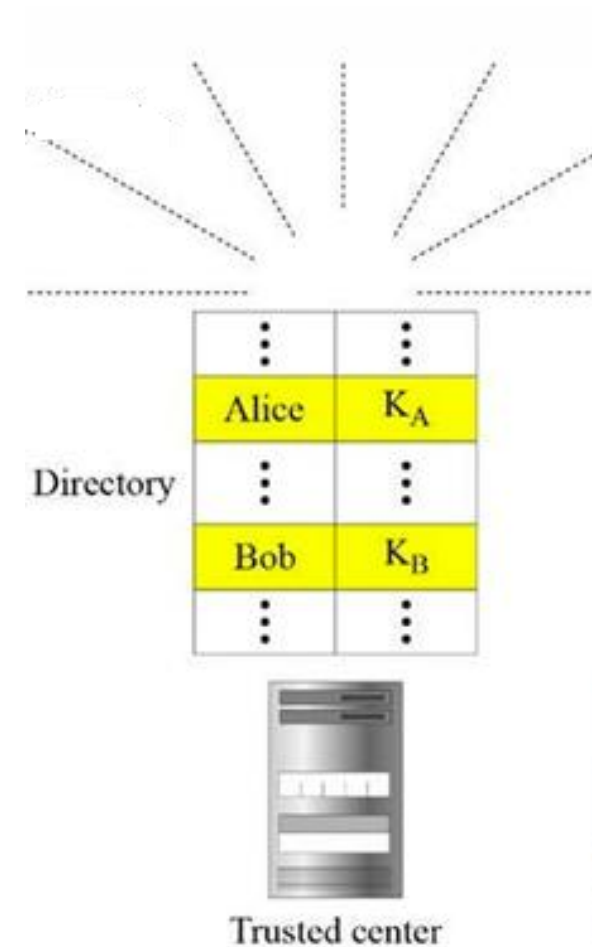


- ❑ Trong mật mã khóa công khai/ bất đối xứng, khóa công khai được cung cấp cho công chúng.

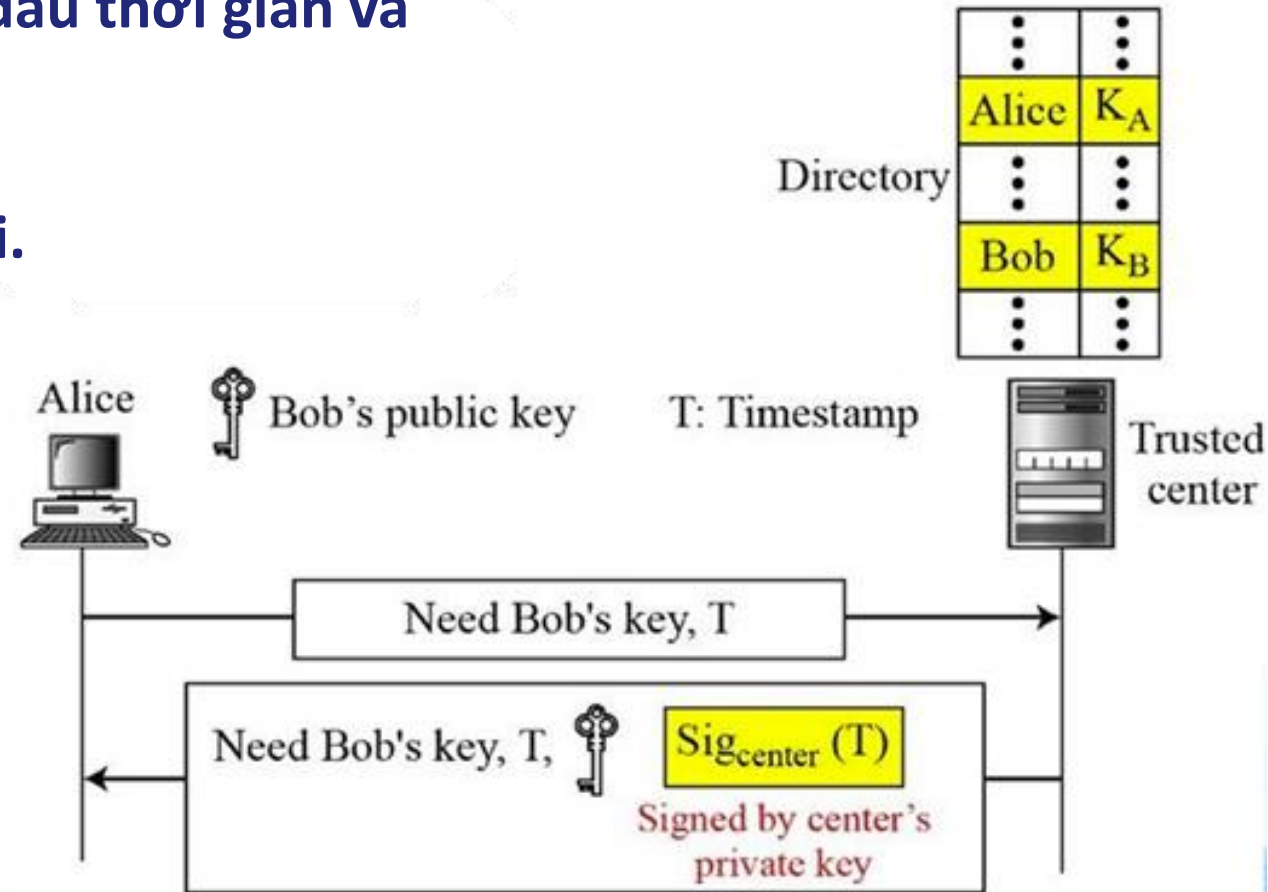
- Tuy nhiên, cách tiếp cận này không an toàn; nó có thể bị giả mạo.

- ❑ Trung tâm đáng tin cậy Trusted Center:

- Một cách tiếp cận an toàn hơn
- Trung tâm giữ lại một thư mục các khóa công khai.

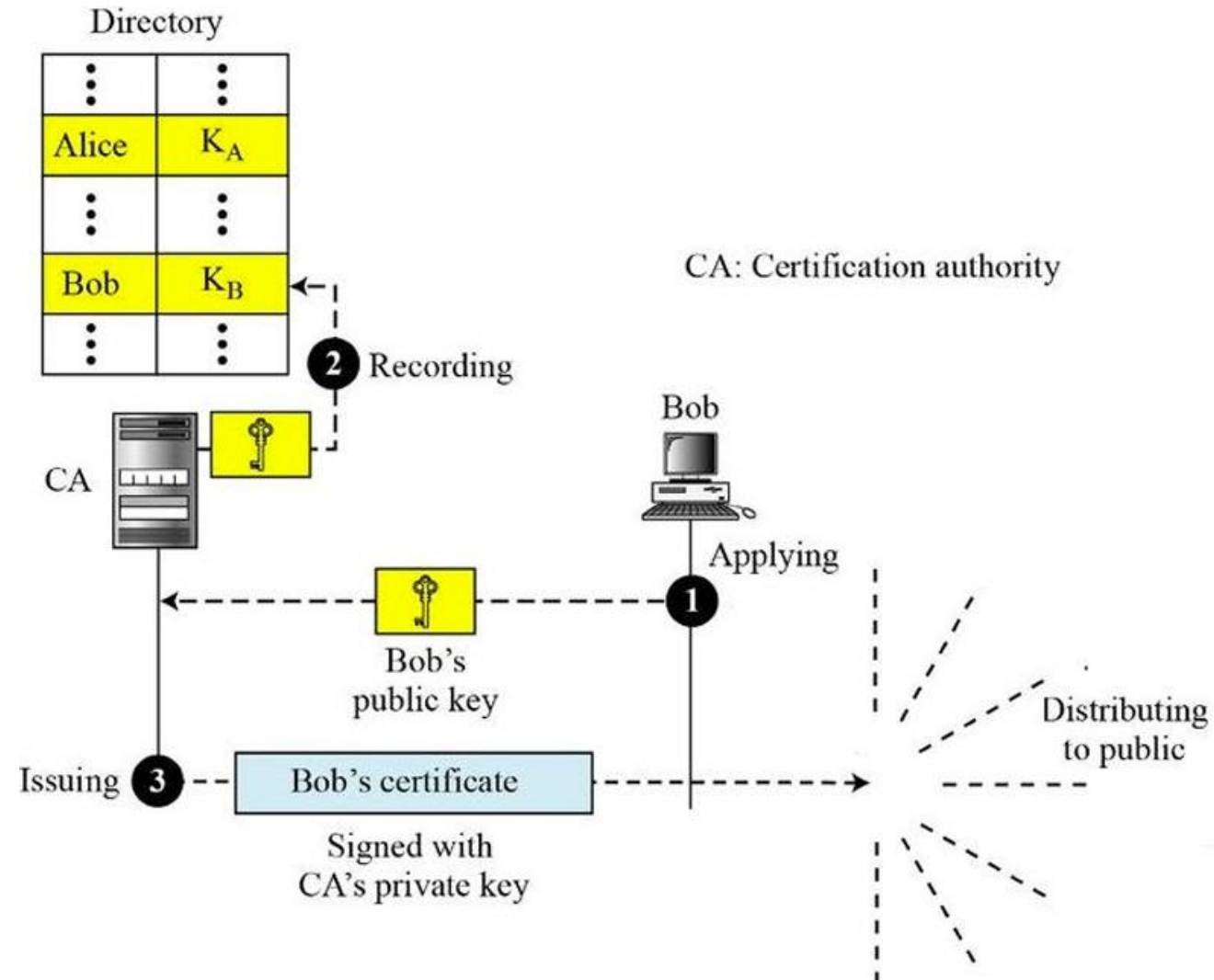


- ❑ Mục tiêu: đạt được mức độ bảo mật cao hơn
 - ❑ Thông báo khóa công khai có thể bao gồm dấu thời gian và được ký bởi cơ quan có thẩm quyền
- => để ngăn chặn việc chặn và sửa đổi phản hồi.

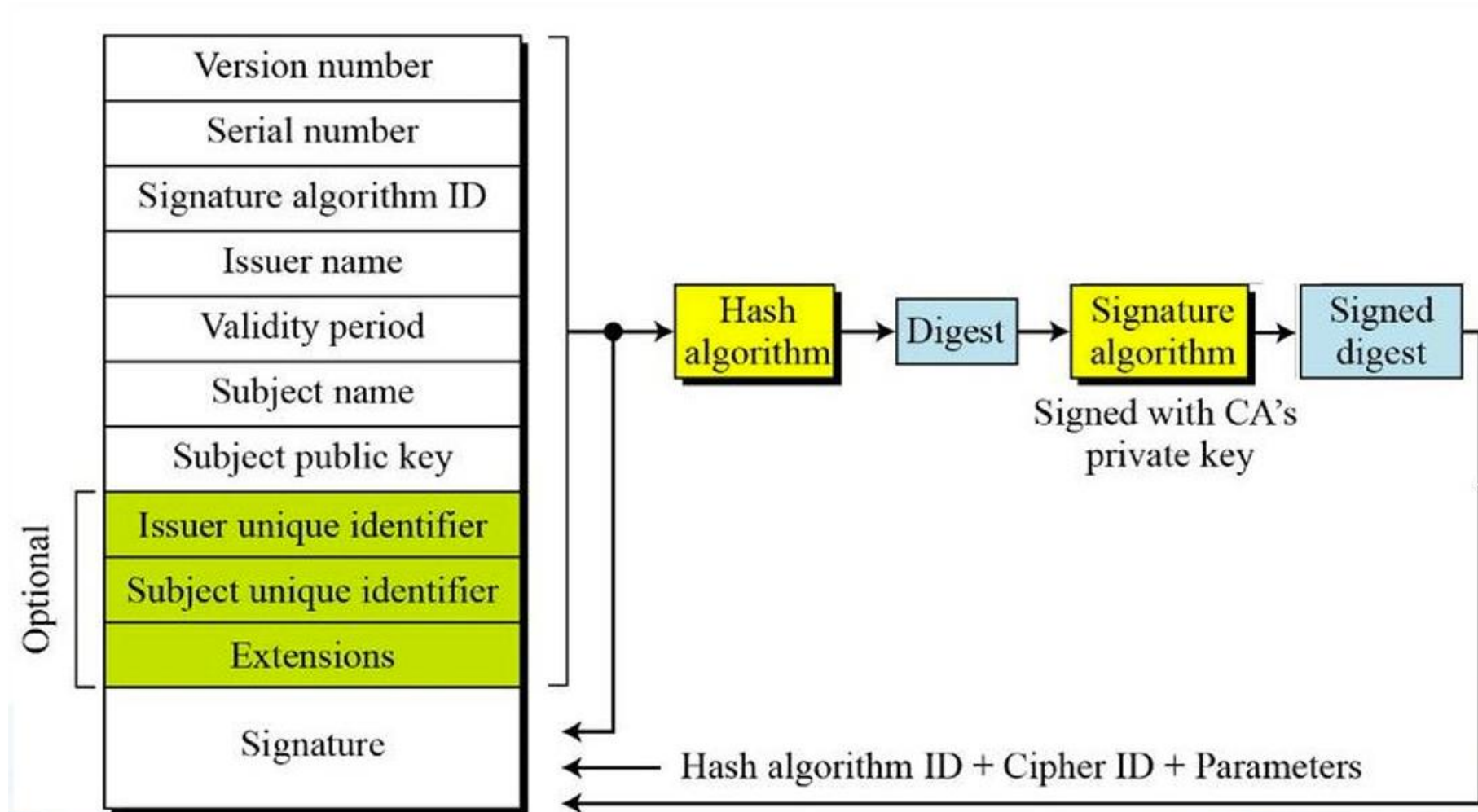


- ❑ CA là cơ quan cấp chứng chỉ để xác thực danh tính của các thực thể (như trang web, địa chỉ email, công ty hoặc cá nhân) và ràng buộc chúng với các khóa mật mã thông qua việc phát hành các tài liệu điện tử được gọi là chứng chỉ số.
- ❑ Chứng chỉ số cung cấp:
 - Xác thực, bằng cách dùng làm thông tin xác thực để xác thực danh tính của thực thể được cấp.
 - Mã hóa, để liên lạc an toàn qua các mạng không an toàn như internet.
 - Tính toàn vẹn của tài liệu Ký kết với chứng chỉ để chúng không thể bị thay đổi bởi bên thứ ba trong quá trình vận chuyển..

□ Quy trình của CA



- ❑ X509 (1988) là một định dạng chuẩn cho chứng chỉ khóa công khai, các cặp khóa mật mã với các danh tính như trang web, cá nhân hoặc tổ chức.
- ❑ Các ứng dụng phổ biến của chứng chỉ X.509 bao gồm:
 - SSL /TLS và HTTPS để duyệt web xác thực và mã hóa
 - Email đã ký và được mã hóa thông qua S/MIME giao thức
 - Ký mã, Ký văn bản
 - Xác thực ứng dụng khách
 - ID điện tử do chính phủ cấp
- ❑ Hoạt động của X.509: cấp phát mới, gia hạn (khi hết hạn), thu hồi (khi có sự cố)



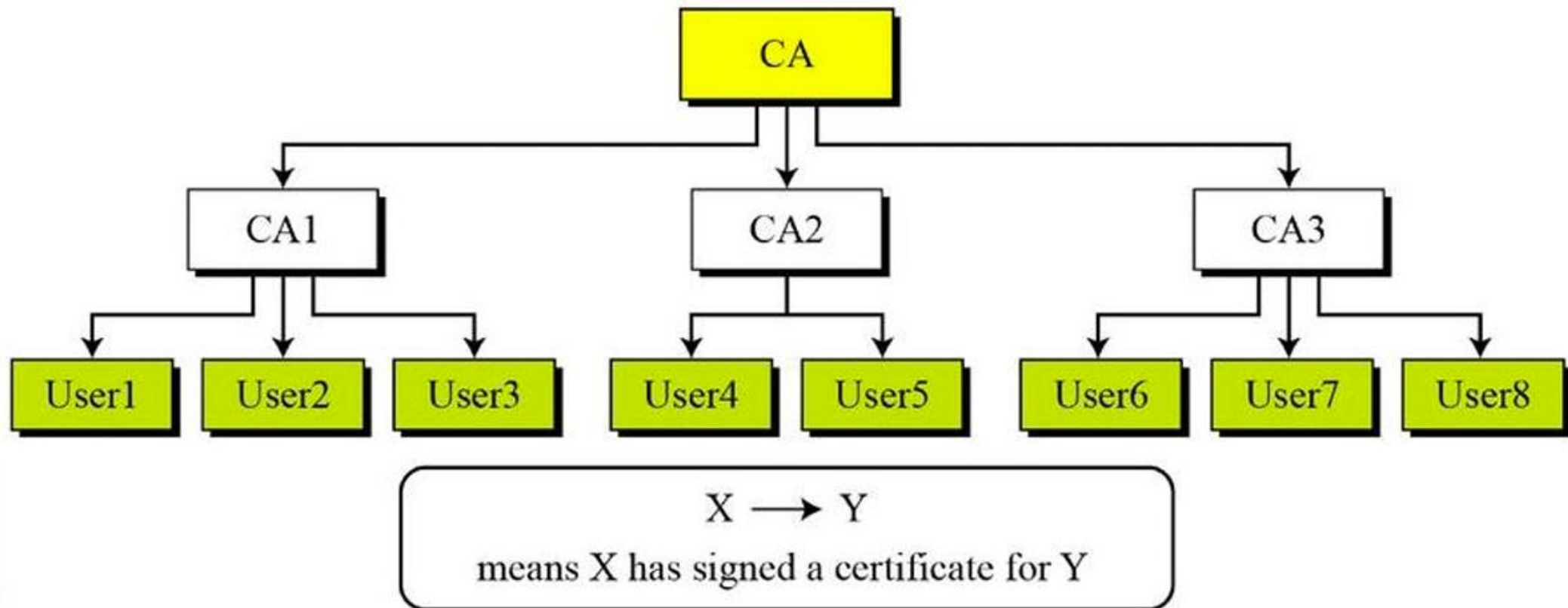
❑ (PKI- Public-Key Infrastructures)

- Là một mô hình để tạo, phân phối và thu hồi chứng chỉ dựa trên X.509.
- TETF (Internet Engineering Task Force) đã tạo ra cơ sở hạ tầng khóa công khai X.509

❑ Hoạt động của PKI:

- Cấp phát chứng chỉ mới, gia hạn (khi hết hạn), thu hồi (khi có sự cố)
- Lưu trữ và cập nhật Keys theo yêu cầu của thành viên
- Cung cấp dịch vụ cho các giao thức khác: một số giao thức bảo mật Internet, chẳng hạn như IPSec và TLS

- ❑ Mô hình tin cậy xác định các quy tắc chỉ định cách người dùng có thể xác minh chứng chỉ nhận được từ CA.
- ❑ Mô hình phân cấp: cấu trúc kiểu cây có CA gốc.



- ☐ Mã hóa khóa bất đối xứng (hoặc mã hóa khóa công khai)
 - Public key
 - Private key
- ☐ Toán học liên quan đến mã hóa
- ☐ Thuật toán RSA – tạo cặp khóa
- ☐ Thuật toán trao đổi khóa Diffie and Hellman
- ☐ Giao thức quản lý Key



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương IX

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn